Aprendizagem Aplicada à Segurança

Class 7: Anomaly Detection III, testing the detectors as an adversary would

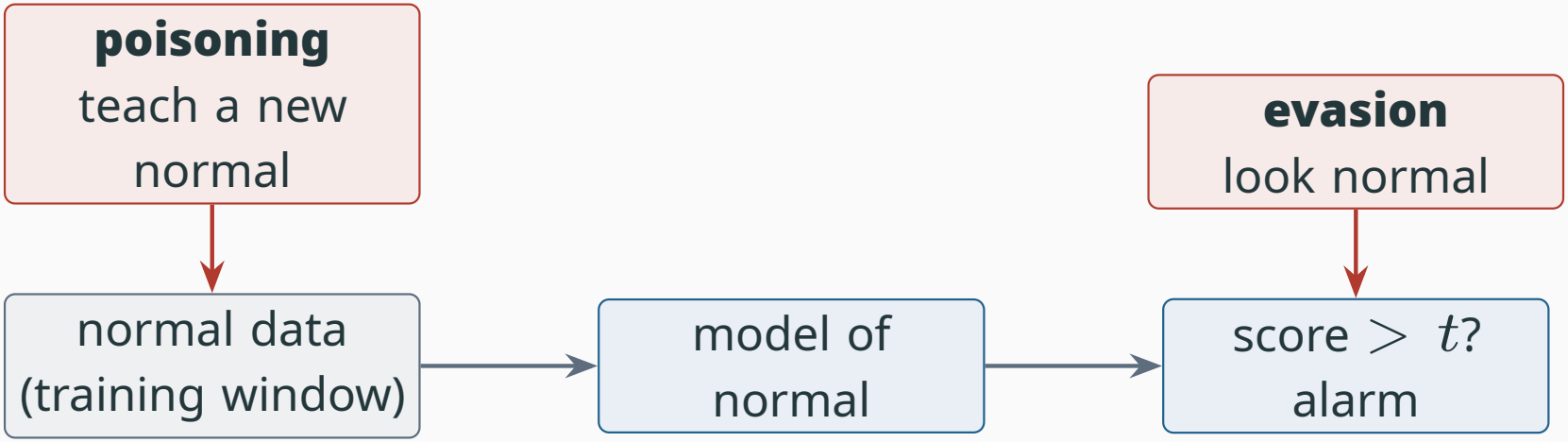
Mário Antunes

October 30, 2026

Universidade de Aveiro

An anomaly detector faces someone who adapts

- Spam (class 04): change the words. What is the equivalent for an anomaly detector?



- Today: play the adversary against **our own** detectors to learn what their alarms rest on.

Terminology: scope and threat model

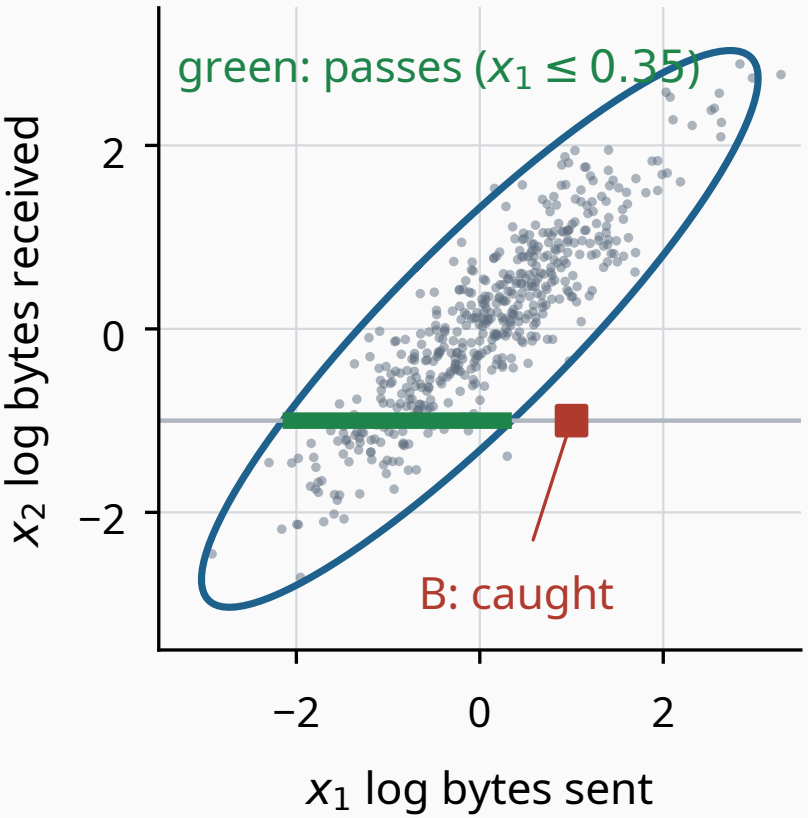
- Our models, the public KDD99 data, the synthetic Example 1 and Example 2, all offline, in **feature space**.
- The aim is the defender's: measure robustness, find the features an alarm rests on, choose defences.
- A result means something only with its **threat model**: goal, capability, knowledge, stage (Biggio et al. 2013; Vassilev et al. 2025).

Element	Question
goal	evasion (test time) or poisoning (training time)?
capability	which features can change without changing the attack?
knowledge	normal data? scores? the model itself?
cost	queries, edits, rounds, slower attack

Constraints: an attack must stay an attack

- In spam any word could be added. A network connection is not free text:
- **Fixed**: protocol, service, flag, error rates, failed logins, root shells: what the attack *does*.
- **Mutable**: duration, bytes, connection counts: volume and timing.
- An “evasion” that changes a fixed feature is a different (often harmless) connection: it does not count.
- Feature-space results are an upper bound of what traffic can achieve (Han et al. 2021).

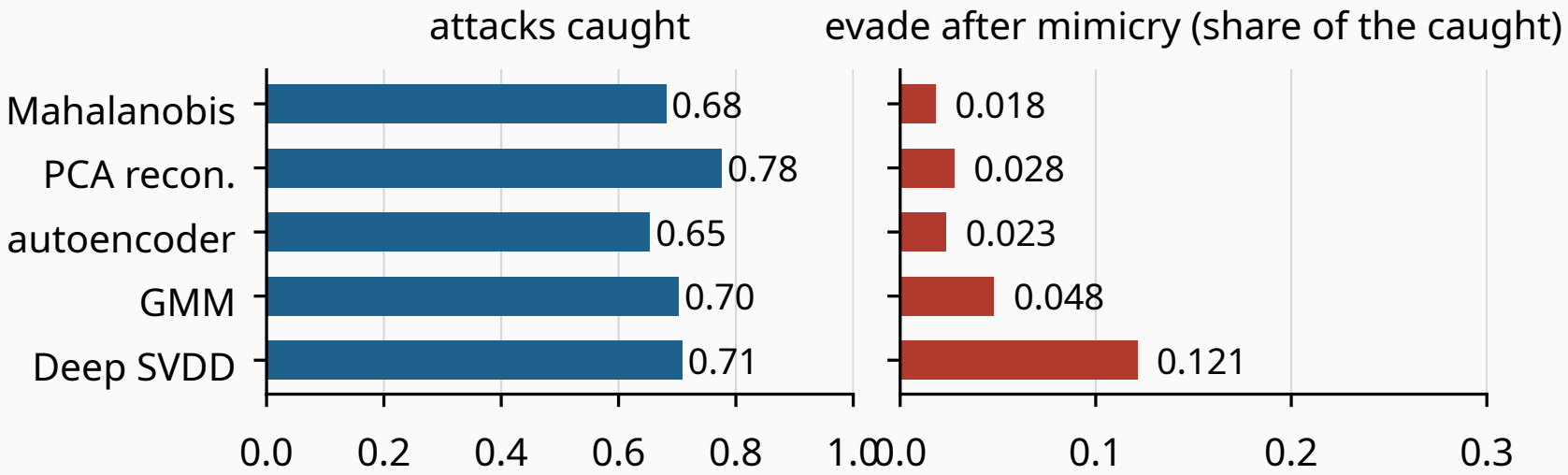
Example 1: evasion has a price



- B $= (1, -1)$ must pass the Mahalanobis detector at 1% FPR ($d_M^2 \le 9.21$) keeping $x_2 = -1$.
- That needs $x_1 \le 0.35$ (derivation: appendix).
- B passes only by sending **less per session**: a **slower** attack lasts longer.

Mimicry on KDD99: borrow normal volume and timing

- For each caught attack, take the nearest normal row in the **fixed** features; copy its **mutable** ones (Wagner and Soto 2002).



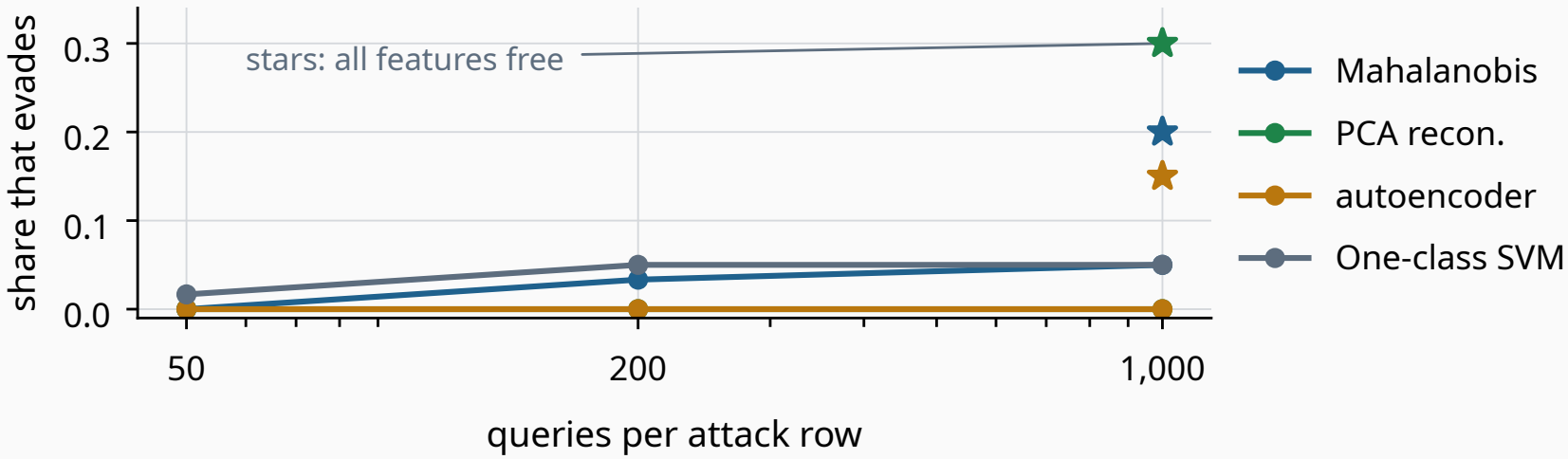
- No query is needed. Evasion is rare: detectors catch attacks by what they **do**, not by size.
- The r2l and u2r rows, near the threshold, evade first.

DEMO 07

notebooks/02-anomaly/notebook_07.ipynb

Black-box search with a query budget

- Per query the attacker sees a score; a random step on one mutable feature is kept if the score drops.



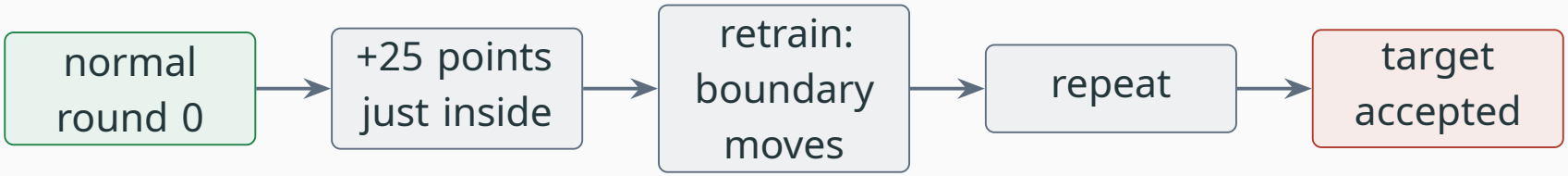
- Share of 60 caught attacks that evade: at most 5% with the constraint; free every feature (stars) and it reaches 15-30%.
- The **feasible region**, not the search, is the limit.

What evasion tells the defender

- A detector is as robust as the features its alarms rest on are **hard to change**.
- r2l and u2r rows sit close to the threshold (they look like logins): they evade first.
- Deep SVDD evades most under mimicry (0.12): a learned space can lean on features an attacker controls.
- Spam reached 100% evasion because words were free; here the protocol itself constrains the attacker.

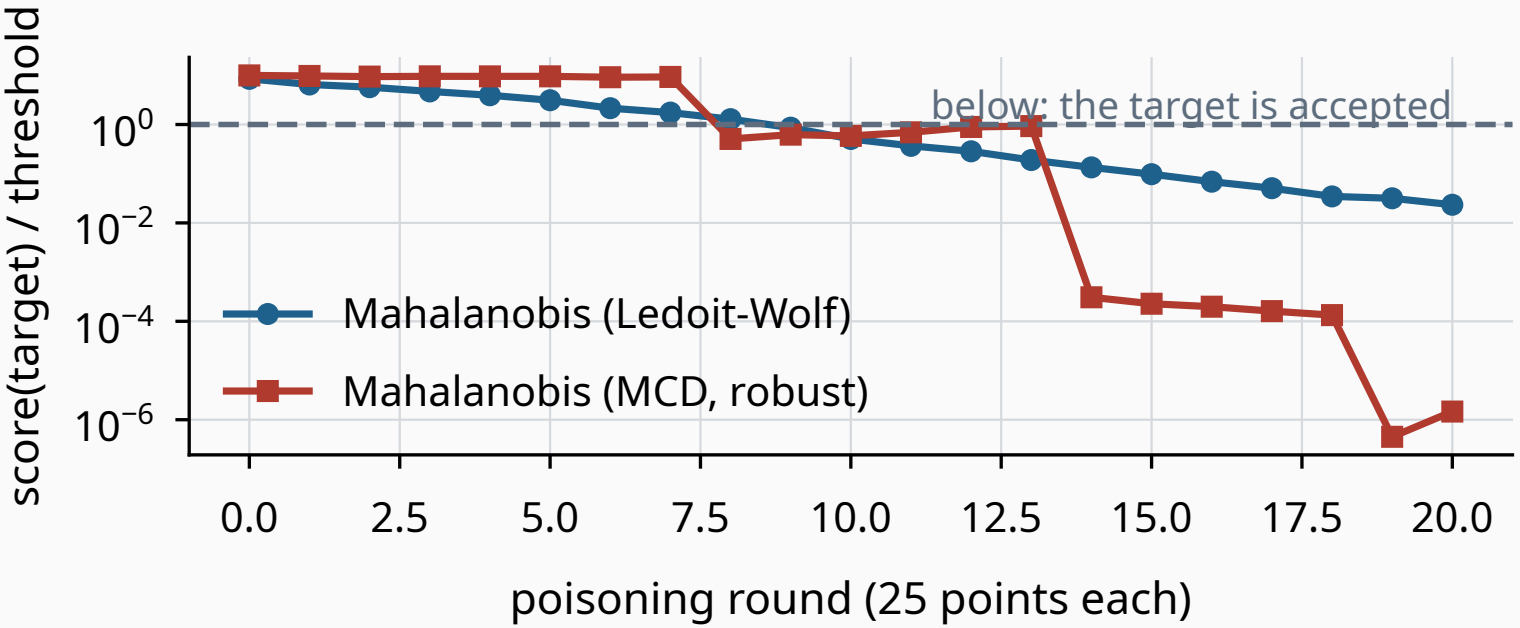
The boiling frog

- A detector retrained on recent traffic follows legitimate change, and also an attacker's.
- Each round the attacker adds points just **below** the threshold, toward the target (Rubinstein et al. 2009; Kravchik and Shabtai 2020).



- Example 1, target $(2, -2)$, $d_M^2 = 77.7$ under the clean model; window of 500 points.

Robust statistics do not stop a patient attacker



- Both estimators accept the target after 8 or 9 rounds (200 to 225 poison points, 40-45% of the window).
- MCD discards *scattered* outliers; the poison is a tight cluster that MCD keeps.
- Robust estimators do not stop an adaptive adversary.

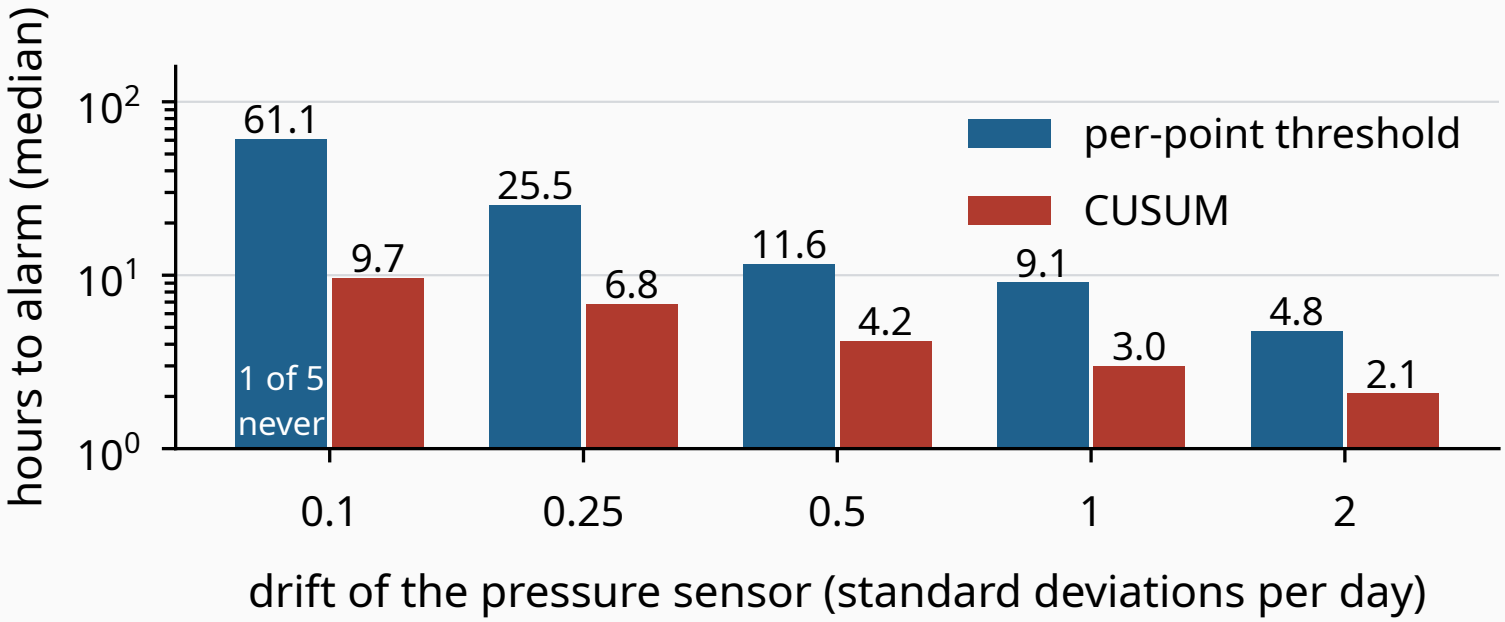
DEMO 08

notebooks/02-anomaly/notebook_08.ipynb

Slow drift beats a per-point threshold

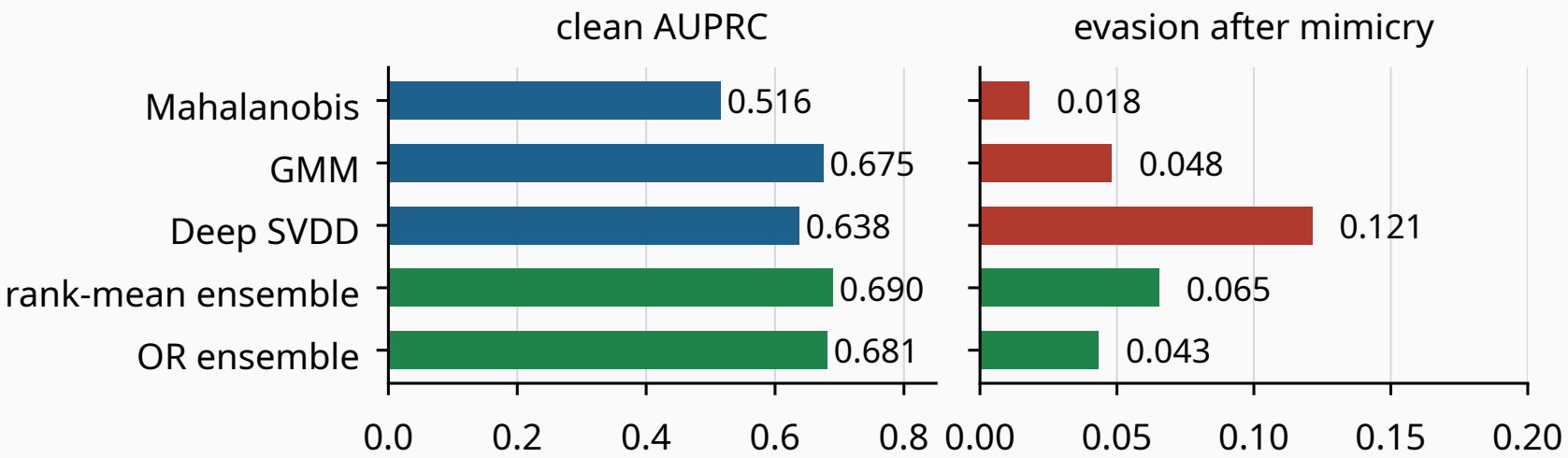
- Example 2: the pressure sensor drifts slowly.
- **CUSUM** (Page 1954) adds up small deviations of the residual r_t; alarm if $S_t > h$ (median of 5 runs, no false alarms):

$$S_t = \max\left(0,\ S_{t-1} + (r_t - \mu)/\sigma - k\right) \quad \text{(definition)}$$



Ensembles: fool every member at once

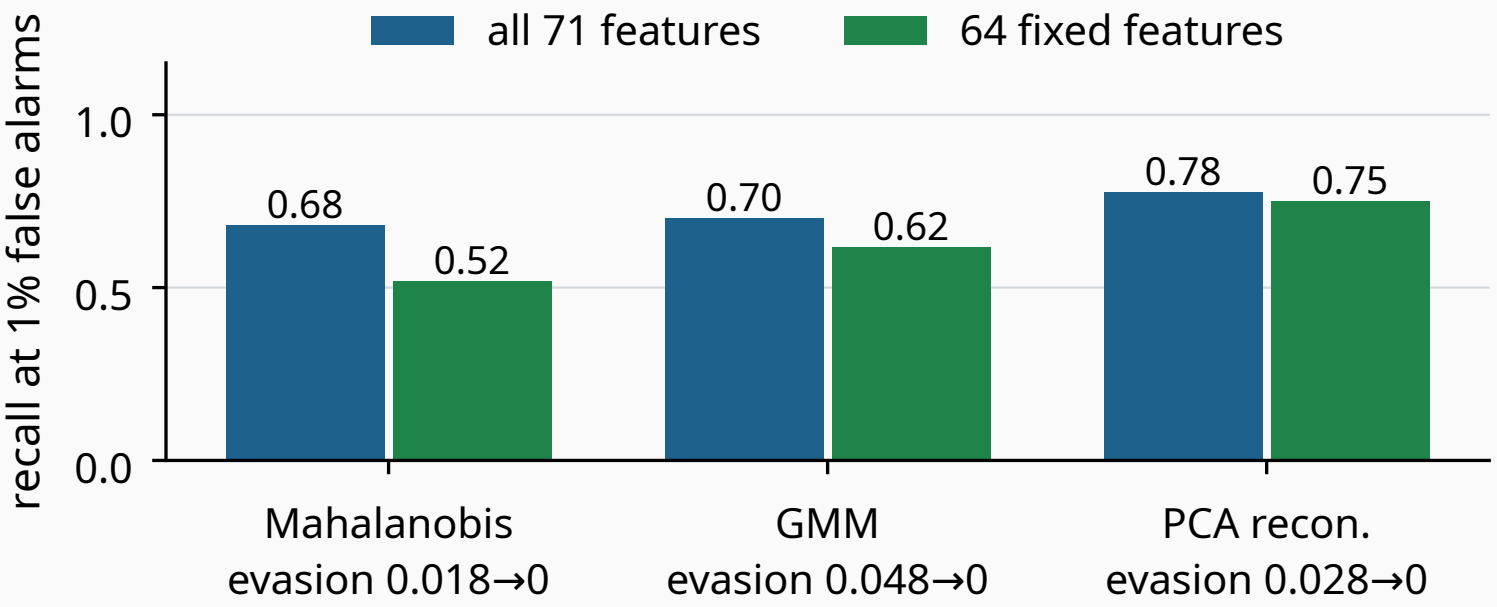
- **Rank mean:** average the ranks of the scores. **OR:** any member alarms, each at $1\%/m$.



- The rank-mean ensemble is the best clean detector of the module; its robustness lies *between* its members'.

Robust features: score only what the attack needs

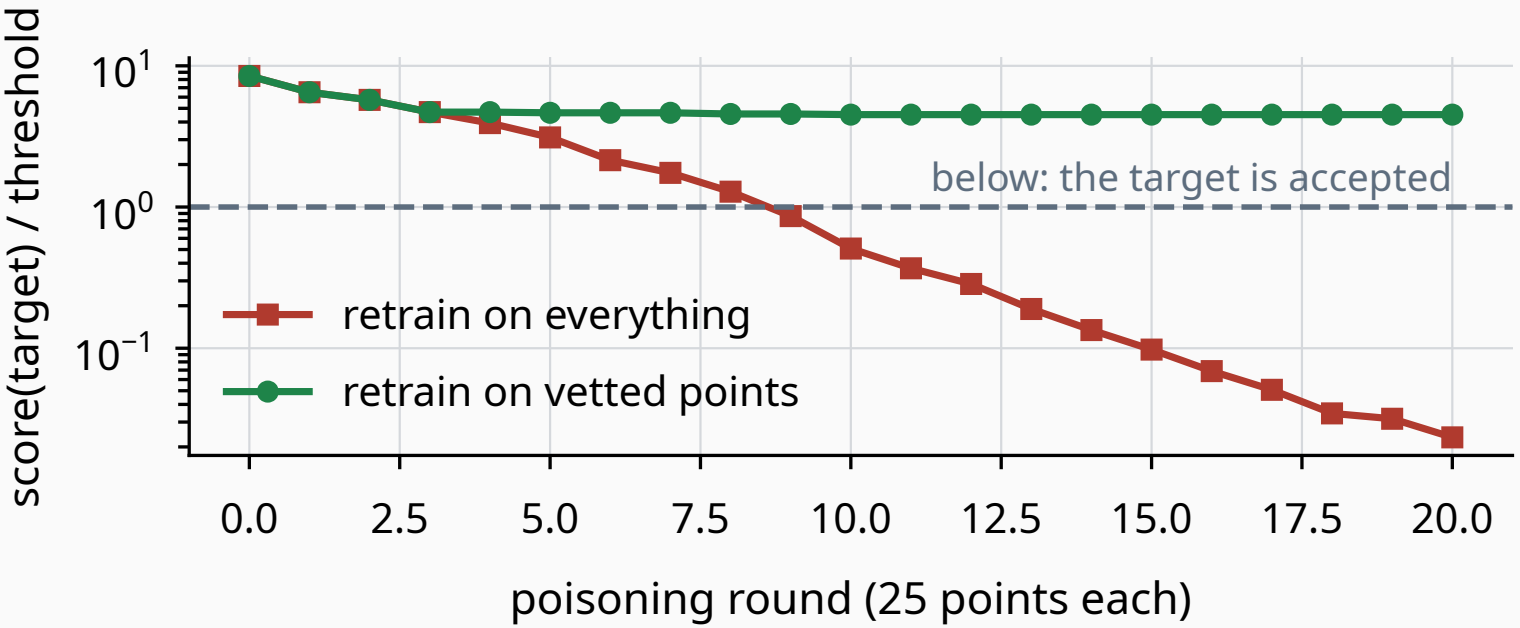
- Fit on the 64 **fixed** features: mimicry of volume and timing cannot move the score.



- PCA loses little, Mahalanobis a quarter of its recall: choose by what an attacker can change, then **measure**.

Vetted retraining against the boiling frog

- Keep a **frozen reference** fitted once on trusted data.
- Retrain only on points it accepts (0.1% false alarms).



- 56 of 500 poison points pass the vetting; the model moves a little, then stops: the target is never accepted.

DEMO 09

`notebooks/02-anomaly/notebook_09.ipynb`

Summary: every defence has a price and an answer

Defence	Stops	Attacker's answer	Cost
OR ensemble	attacks tuned to one model	fool all members	compute, false alarms
robust features	mimicry of volume, timing	change the attack	clean recall
vetted retraining	boiling frog	stay in the old region	slow adaptation
CUSUM	slow drift	stop drifting	delay, tuning k, h

- **No defence is final; each changes the price.** Report clean metrics *and* robustness.

Labs and practice guide

Notebook	Content
07	threat model, Example 1 price, mimicry, black-box search with budget, constraints
08	boiling frog (Mahalanobis, MCD), centre monitoring, slow drift and CUSUM
09	ensembles, robust features, vetted retraining, summary of costs

- **Guide** `practice/anomaly/guide_03_03`: mimicry, a budgeted black-box search, the boiling frog with and without vetting, CUSUM.

Take-aways

- An anomaly detector is attacked through its **data** (poisoning) or its **threshold** (evasion).
- Constraints decide the outcome: features the attack needs are robust, volume and timing are not.
- Robust statistics resist noise, not a patient adversary; vetting and monitoring the model's movement do.
- Slow attacks need accumulated evidence (CUSUM), not per-point thresholds.
- Measure every defence twice: on clean data and under attack.

Solving Example 1's evasion

- Constraint: $(x_1^2 - 1.8x_1x_2 + x_2^2)/0.19 \leq 9.21$ with $x_2 = -1$.
- Multiply by 0.19: $x_1^2 + 1.8x_1 + 1 \leq 1.75$, so $x_1^2 + 1.8x_1 - 0.75 \leq 0$.
- Roots: $x_1 = \frac{-1.8 \pm \sqrt{1.8^2 + 4 \cdot 0.75}}{2} = \frac{-1.8 \pm 2.498}{2}$, i.e. -2.15 and 0.35.
- The feasible sessions are $-2.15 \leq x_1 \leq 0.35$: B must send less than at $x_1 = 1$.

CUSUM as a sequential test

- Under normal operation $z_t = (r_t - \mu)/\sigma$ has mean 0; under a shift of size δ it has mean δ.
- The log-likelihood ratio of "shift" vs "no shift" for one sample is $\delta z_t - \delta^2/2$; with $k = \delta/2$ it is proportional to $z_t - k$.
- S_t is the largest sum of these log-ratios over windows ending at t (the $\max(0, \cdot)$ restarts after evidence against a shift).
- k is half the smallest shift worth detecting; h trades delay against false alarms (Page 1954).

References

Biggio, Battista, Igino Corona, Davide Maiorca, et al. 2013. “Evasion Attacks Against Machine Learning at Test Time.” European Conference on Machine Learning and Knowledge Discovery in Databases (ECML PKDD).

Han, Dongqi, Zhiliang Wang, Ying Zhong, et al. 2021. “Evaluating and Improving Adversarial Robustness of Machine Learning-Based Network Intrusion Detectors.” IEEE Journal on Selected Areas in Communications 39 (8).

Kravchik, Moshe, and Asaf Shabtai. 2020. Can’t Boil This Frog: Robustness of Online-Trained Autoencoder-Based Anomaly Detectors to Adversarial Poisoning Attacks.

Page, E. S. 1954. “Continuous Inspection Schemes.” Biometrika 41 (1/2).

Rubinstein, Benjamin I. P., Blaine Nelson, Ling Huang, et al. 2009. “ANTIDOTE: Understanding and Defending Against Poisoning of Anomaly Detectors.” ACM SIGCOMM Internet Measurement Conference (IMC).

Vassilev, Apostol, Alina Oprea, Alie Fordyce, Hyrum Anderson, Xander Davies, and Maia Hamin. 2025. Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations. NIST AI 100-2e2025. National Institute of Standards; Technology. https://doi.org/10.6028/NIST.AI.100-2e2025.

Wagner, David, and Paolo Soto. 2002. “Mimicry Attacks on Host-Based Intrusion Detection Systems.” ACM Conference on Computer and Communications Security (CCS).